

TD/TP Remédiation

CNAM

24 Mai 2023

1 Introduction

L'une des tâches les plus importantes de la remédiation lors de la réponse aux incidents et le traitement des preuves numériques est la capacité d'identification à grande échelle de machines compromises afin de déterminer :

- Le périmètre de compromission.
- La nécessité de restaurer un système ou non.

L'outil DFIR ORC Fastfind est un outil de traitement numérique des preuves qui peut faciliter grandement cette tâche. Dans ce travail dirigé et pratique, nous examinerons de plus près cet outil, son fonctionnement, et comment il peut être utilisé dans le cadre de la remédiation.

2 Présentation de FastFind

FastFind est un outil présent dans la suite d'Outils de Recherche de Compromission (ORC) de l'ANSSI. Le but de FastFind est de vérifier la présence d'indicateurs connus sur de des milliers de systèmes. Pour atteindre cet objectif, FastFind utilise un fichier de configuration XML incorporé en tant que ressource pour spécifier les indicateurs à rechercher.

2.1 Exemple de fichier de configuration

Commençons par un exemple de fichier de configuration afin de comprendre les capacités de l'outil. Télécharger le fichier de configuration XML sur moodle : <https://mpy.moodle.lecnam.net/mod/resource/view.php?id=49106> et examiner ce dernier.

Le fichier de configuration XML pour FastFind contient :

- Un élément racine **<fastfind>** avec un attribut de version qui s'affiche lorsque l'outil s'exécute (identifiant généralement la campagne),
- Une section **<filesystem>** pour rechercher des fichiers spécifiques,
- Une section **<registry>** pour rechercher des clés ou des valeurs de registre,
- Une section **<object>** pour rechercher des objets Windows.

Dans chacune de ces sections, trois éléments supplémentaires peuvent être spécifiés :

- Des emplacements, pour spécifier où rechercher (exemple : **C:**).
- Une collection d'indicateurs à rechercher:
 - Éléments **ntfs_find** et **ntfs_exclude** pour les indicateurs de système de fichiers.
 - Éléments de **registre_find** pour les indicateurs de registre.
 - Éléments **object_find** pour les indicateurs d'objet.

2.1.1 Syntaxe des emplacements spécifiques

Un emplacement est un chemin d'accès à un volume NTFS spécifique. Typiquement, un chemin d'accès peut être :

- un chemin de volume monté (**C:**)
- une variable d'environnement ou une variable dynamique (**%SYSTEMDRIVE%**, **{UserProfiles}**,...)

D'autres type d'emplacements sont également disponibles ici :

https://dfir-orc.github.io/configuring_locations.html

En XML on utilise la balise **<location>**. Exemple:

```

1 <filesystem>
2     <location shadows="yes">%SystemDrive%</location>
3     <ntfs_find name="explorer.exe" />
4     ...

```

2.1.2 Syntaxe des indicateurs de système de fichiers

FastFind, RegInfo et GetThis peuvent sélectionner les entrées du système de fichiers NTFS en fonction de plusieurs indicateurs pour permettre la définition précise des éléments recherchés. Ces indicateurs sont spécifiés en utilisant deux éléments :

- `ntfs_find` pour rechercher un indicateur,
- `ntfs_exclude` pour rejeter une correspondance.

Exemples pour `ntfs_find`:

```
1 <ntfs_find name="qfe.dat" />
2 <ntfs_find size="104857600" />
```

Dans cet exemple, les fichiers possédant le nom "qfe.dat" **OU** ayant une taille de 104857600 octets vont ressortir.

```
1 <ntfs_find name="qfe.dat" size="104857600" />
```

Dans cet exemple, les fichiers possédant le nom "qfe.dat" **ET** ayant une taille de 104857600 octets vont ressortir.

Il s'agit du même fonctionnement pour la clause "**ntfs_exclude**"

La liste des attributs possibles est disponible ici: https://dfir-orc.github.io/configuring_ntfs_opt.html

Exemple:

```
1 <filesystem>
2   <location shadows="yes">%SystemDrive%</location>
3   <yara source="yara.rules" block="2M" timeout="120" overlap="8192" scan_method="
4   filemapping" />
5   <ntfs_find size="694160" md5="1CECAFE147F1CC3E2B9804B8CDA593C9"/>
6   <ntfs_find name="ntdll.dll" yara_rule="is_dll"/>
7   <ntfs_find name_match="gdi*.dll"/>
8   <ntfs_exclude path="\Windows\System32\ntdll.dll"/>
9   <ntfs_exclude path_match="\Windows\System32\gdi*.dll"/>
10  <ntfs_exclude sha1="c766364efd9c9b5aa3a7140a69f0cf5b147bc476"/>
11  <ntfs_exclude size="14966411"/>
12  <ntfs_exclude contains="bcryptprimitives.pdb"/>
13 </filesystem>
```

Les "shadow copies" de volume peuvent être énumérés et ajoutés à la liste des emplacements analysés. Cette fonctionnalité peut être activée en ajoutant l'attribut `shadows="yes"` dans un élément `location`.

Pour en savoir plus sur les volumes shadow : <https://learn.microsoft.com/fr-fr/windows-server/storage/file-server/volume-shadow-copy-service>

2.1.3 Syntaxe des indicateurs de registre

L'élément `registry_find` est utilisé pour spécifier une règle sur laquelle faire correspondre une clé, une valeur ou des données de registre. Il existe différents types de règles qui peuvent être combinées (ET logique) pour obtenir les critères souhaités. Tout comme pour `ntfs_find`, chaque règle est spécifiée en tant qu'attribut de `registry_find`.

Exemple:

```

1 <registry>
2   <location>%SystemDrive%\</location>
3   <hive name="NTUSER">
4     <ntfs_find name="NTUSER.DAT"/>
5     <registry_find key_path="\Software\Microsoft\Internet Explorer\Main" value="
6     Check_Associations" data="no"/>
7   </hive>
8   <hive name="SOFTWARE">
9     <ntfs_find name="SOFTWARE"/>
10    <registry_find key_path="\Microsoft\Windows\CurrentVersion\Run" value="
11    SecurityHealth"/>
12  </hive>
13 </registry>

```

La liste des attributs possibles est disponible ici : <https://dfir-orc.github.io/RegInfo.html#reginfo-registryfind>

2.1.4 Syntaxe des indicateurs d'objet

L'élément `object_find` est utilisé pour répertorier l'ensemble des objets compatible Microsoft Windows actuellement présents sur le système analysé.

Exemple:

```

1 <object>
2   <object_find type="Mutant" name="foo"/>
3   <object_find type="File" name="foobar"/>
4 </object>

```

La liste des attributs compatibles est disponible ici : <https://dfir-orc.github.io/ObjInfo.html>

2.2 Utilisation de l'outil

L'outil s'exécute via la ligne de commande Windows.

Une utilisation basique de l'outil peut-être formulé de la façon suivante:

```

1 DFIR-Orc.exe FastFind /config=fastfind.xml /out=fastfind_sortie.xml

```

Dans cet exemple, deux arguments sont passés à l'outil DFIR-ORC:

- **/config=** : Prend un fichier de configuration XML.
- **/out=** : Le nom et format du fichier résultant.

2.2.1 "Récupération" d'un fichier

Fastfind possède un analyseur MFT qui peut être configuré pour inclure les enregistrements supprimés.

La Table de Fichiers Master (MFT) est une table qui est incluse avec tous les systèmes d'exploitation Windows, y compris Windows XP, Vista, 7, 8 et 10. Il s'agit d'un fichier enregistré sur le disque dur qui stocke des informations sur chaque fichier et dossier présent sur le disque dur. Chaque entrée MFT contient des informations détaillées sur l'objet du dossier ou du fichier, telles que sa taille, l'emplacement sur le disque dur, la date de création et de modification, les attributs et plus encore.

```
1 /ResurrectRecords=<yes|no|resident>
```

- yes : Activer la récupération des enregistrements supprimés
- no : Ne pas récupérer les enregistrements supprimés
- resident : Activer la récupération des enregistrements de **fichier** supprimés uniquement

3 TP : Configuration d'un FastFind pour la recherche de compromission

Dans cette partie pratique, nous allons déposer plusieurs fichiers bénins sur une machine Windows (machine virtuelle recommandée), et tenter de les retrouver grâce à l'outil FastFind.

3.1 Étape 1 : Dépôts des fichiers à supprimer pour la simulation d'une machine compromise

Dans cette partie, nous allons préparer la machine Windows pour inclure des fichiers à retrouver par FastFind. Suivre les instructions suivantes:

- Télécharger l'archive disponible sur moodle : <https://mpy.moodle.lecnam.net/mod/resource/view.php?id=49105> et extraire les fichiers.
- Déplacer le fichier "Note de rançon" sur le bureau de l'utilisateur connecté.
- Créer un dossier "tmp" à la racine du système de fichier ("%SystemDrive%\tmp")
- Déplacer les fichiers "tmp" et "superpascool.dll" à l'emplacement nouvellement créé ("%SystemDrive%\tmp")

3.2 Etape 2 : Création du fichier de configuration FastFind

Dans ce scénario, vous avez isolé grâce à l'équipe d'investigation les indicateurs de compromission suivants:

- DLL malveillante "NomAléatoire.dll" avec une signature MD5 suivante : **C7E526A5B820525C561F6C7D21C84951**
- Note de rançon toujours présente dans les répertoires utilisateurs. Le fichier contient l'adresse email de l'adversaire: "**superFakeRansomware@google.com**"
- Fichier de configuration du malware pour le serveur de Command&Control possédant l'indicateur de compromission: **192.168.234.299** (fausse IP invalide de l'attaquant)

Consigne: *Construire le fichier de configuration FastFind permettant de retrouver l'ensemble des indicateurs de compromissions sur votre machine.*

Remarque: L'exécution de FastFind peut être longue selon la configuration que vous avez mis en place. Utilisez un maximum d'informations contextuelles pour optimiser votre configuration.